

	PROCEDURE 06_Cloud	Date de création : 13/02/2026	Nombre de page : 13
		Date de révision : /	Version : 1.0
Référence : AZR-IDM-SEC	Configuration du Conditional Access et MFA		

Table des matières

1. Introduction ----- 2

2. Contexte et Justification ----- 2

3. Concepts Clés ----- 2

4. Prérequis ----- 3

5. Pièges AZ-104 ----- 3

6. Méthode 1 : Configuration via Portail Azure ----- 4

 6.1. Activer les Security Defaults (Approche simple) ----- 4

 6.2. Désactiver les Security Defaults (Avant de Passer au Conditional Access) ----- 4

 6.3. Créer une Policy Conditional Access (Exiger le MFA) ----- 5

 6.4. Créer une Policy Conditional Access (Bloquer l’Accès par Pays) ----- 6

 6.5. Créer un Named Location (Emplacement Nommé) ----- 7

 6.6. Tester une Policy en Mode Report-Only ----- 8

7. Méthode 2 : Configuration via Azure CLI / Microsoft Graph CLI ----- 8

 7.1. Lister les Politiques Existantes ----- 8

 7.2. Créer une Policy Conditional Access ----- 9

 7.3. Passer une Policy en Mode Activé ----- 10

 7.4. Supprimer une Policy ----- 10

8. Méthode 3 : Configuration via PowerShell (Microsoft Graph) ----- 10

 8.1. Connexion au Module Microsoft Graph ----- 10

 8.2. Créer une Policy Conditional Access ----- 10

 8.3. Lister et Vérifier les Politiques ----- 11

 8.4. Modifier une Policy (Report-Only → Enabled) ----- 11

 8.5. Supprimer une Policy ----- 11

9. Vérifications ----- 12

10. Dépannage ----- 12

11. Conseils et Bonnes Pratiques ----- 12

12. Procédures Liées ----- 13

1. Introduction

Cette procédure décrit comment protéger les connexions à votre tenant Azure/Entra ID en exigeant des preuves d'identité supplémentaires (MFA) et en appliquant des conditions d'accès (lieu géographique, appareil, rôle de l'utilisateur). Le Conditional Access est le moteur de décision central de la sécurité identitaire dans Azure.

2. Contexte et Justification

Un mot de passe seul ne suffit plus. Si un attaquant vole les identifiants d'un Global Admin, il a un accès total au tenant. Le Conditional Access permet de créer des règles du type :

- « Si l'utilisateur est un administrateur, exiger le MFA à chaque connexion. »
- « Si la connexion vient d'un pays où l'entreprise n'opère pas, bloquer l'accès. »
- « Si l'utilisateur se connecte depuis un appareil non enregistré, autoriser uniquement l'accès en lecture au mail. »

C'est un modèle « If/Then » : **SI** (conditions) **ALORS** (contrôles d'accès).

3. Concepts Clés

Security Defaults : Un ensemble de règles de sécurité prédéfinies par Microsoft, activé par défaut sur les nouveaux tenants. Il impose le MFA à tous les utilisateurs et bloque l'authentification legacy (protocoles anciens comme POP3/IMAP sans MFA). C'est le « pack de base ». Il est gratuit mais pas personnalisable, c'est tout ou rien.

Conditional Access : Le remplacement avancé des Security Defaults. Il permet de créer des règles granulaires et personnalisées. Il nécessite une licence **Entra ID P1** (incluse dans Microsoft 365 E3) ou **Entra ID P2** (incluse dans Microsoft 365 E5). Les Security Defaults doivent être désactivées pour utiliser le Conditional Access.

Policy Conditional Access : Une règle composée de trois parties :

- **Assignments (Qui / Quand / D'où)** : Utilisateurs/groupes ciblés, application cloud concernées, conditions (localisations, plateforme, risque de connexion).
- **Access Controls (Quoi faire)** : Accorder avec des exigences (MFA, appareil conforme, conditions d'utilisation) ou Bloquer.
- **State (Etat)** : Enable (actif), Disabled (Inactif), ou Report-Only (évalue sans appliquer, idéal pour tester).

MFA (Multi-Factor Authentication) : Exige un deuxième facteur au-delà du mot de passe. Les méthodes supportées par Entra ID :

Configuration du Conditional Access et MFA

- **Microsoft Authenticator** (notification push ou code), recommandé.
- **Clé de sécurité FIDO2** (clé USB physique), le plus sûr.
- **SMS / Appel téléphonique**, déconseillé car vulnérable au SIM swapping.
- **TOTP** (code temporaire via une app type Google Authenticator).

Named Location (Emplacement nommé) : Une liste d'adresses IP ou de pays que vous définissez pour les utiliser comme condition dans vos politiques. Par exemple, « Bureau-Paris » = la plage IP du bureau, ou « Pays-Autorisés » = France + Belgique + Luxembourg.

Report-Only : Un état de policy qui évalue les connexions et journalise ce qui SERAIT arrivé (accordé ou bloqué), sans réellement appliquer la décision. Indispensable pour tester avant de passer en production.

4. Prérequis

- ❖ Un tenant Entra ID avec une licence **P1** minimum (pour le Conditional Access). Si vous utilisez un abonnement étudiant ou d'essai, vous pouvez activer un [trial P2 de 30 jours](#) dans Entra ID > Licences.
- ❖ Le rôle **Security Administrator** ou **Conditional Access Administrator** (minimum).
- ❖ Au moins deux comptes utilisateurs de test dans Entra ID (un admin, un utilisateur standard).
- ❖ L'application **Microsoft Authenticator** installée sur votre téléphone (pour tester le MFA).
- ❖ Un groupe de sécurité contenant vos comptes de test (ex : « GRP-Test-CA »).

5. Pièges AZ-104

Security Defaults et Conditional Access sont mutuellement exclusifs. Vous ne pouvez pas avoir les deux actifs en même temps. Si vous activez une policy Conditional Access, vous devez d'abord désactiver les Security Defaults. L'examen teste cette incompatibilité.

Le Conditional Access s'évalue au moment de la connexion, pas en continu. Si un utilisateur se connecte depuis la France (autorisé), puis utilise un VPN vers la Russie (bloqué), sa session existante continue de fonctionner. La policy ne sera réévaluée qu'à la prochaine connexion ou au prochain rafraîchissement de token. L'exception : avec Continuous Access Evaluation (CAE), certains événements critiques (désactivation du compte, changement de mot de passe) peuvent révoquer la session en quasi temps réel.

L'ordre des politiques ne compte pas (pas de priorité). Toutes les politiques sont évaluées en parallèle. Si une policy accorde l'accès avec MFA et qu'une autre bloque l'accès, le blocage gagne toujours. En cas de conflit, la décision la plus restrictive l'emporte.

Report-Only ne bloque personne. C'est un mode d'observation. Les utilisateurs passent toujours, mais le journal d'audit note ce qui ce serait passé. L'examen peut poser des questions du type « la policy est en Report-Only, l'utilisateur sera-t-il bloqué ? », la réponse est toujours non.

Configuration du Conditional Access et MFA

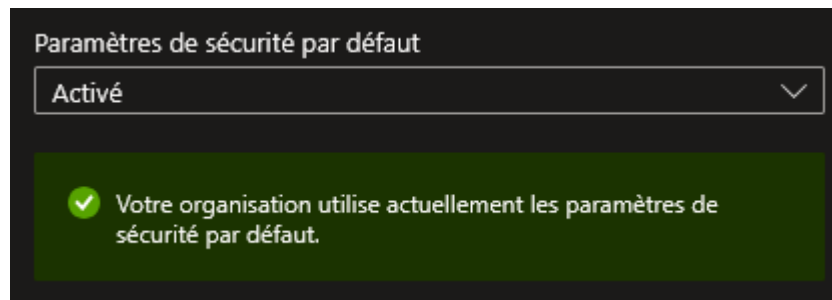
Le compte « break glass » doit être exclu de TOUTES les politiques. C'est un compte d'urgence (sans MFA, avec un mot de passe très long) qui vous permet de récupérer l'accès si toutes les politiques vous bloquent. Microsoft recommande officiellement d'en avoir au moins un.

6. Méthode 1 : Configuration via Portail Azure

6.1. Activer les Security Defaults (Approche simple)

Note : Si vous n'avez pas de licence P1, les Security Defaults sont votre seule option pour le MFA. Si vous avez P1, passez directement à 6.2.

1. Allez dans **Microsoft Entra ID** (anciennement Azure AD) > **Propriétés** (Properties).
2. En bas de la page, cliquez sur **Gérer les paramètres de sécurité par défaut**.
3. Basculez sur **Activé**.

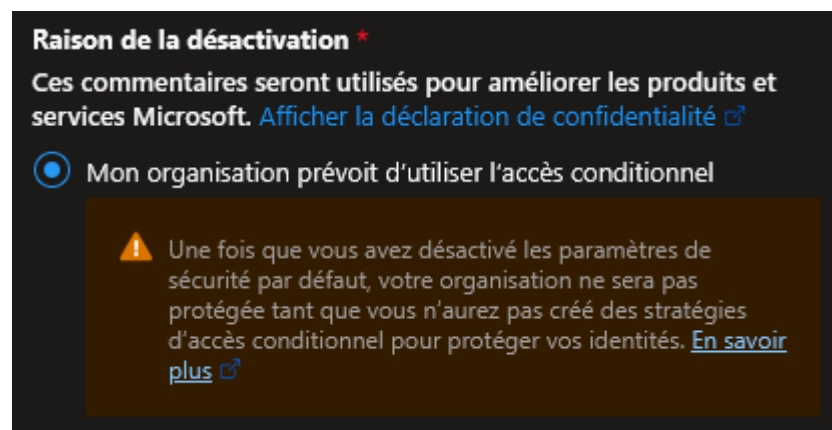


4. **Enregistrer**.

Note : Tous les utilisateurs devront configurer le MFA dans les 14 jours. Après ce délai, le MFA est exigé à chaque connexion

6.2. Désactiver les Security Defaults (Avant de Passer au Conditional Access)

1. Même chemin : **Microsoft Entra ID** > **Propriétés** > **Gérer les paramètres de sécurité par défaut**.
2. Basculez sur **Désactivé**.
3. Azure vous demande une raison, sélectionnez « Mon organisation prévoit d'utiliser le Conditional Access ».

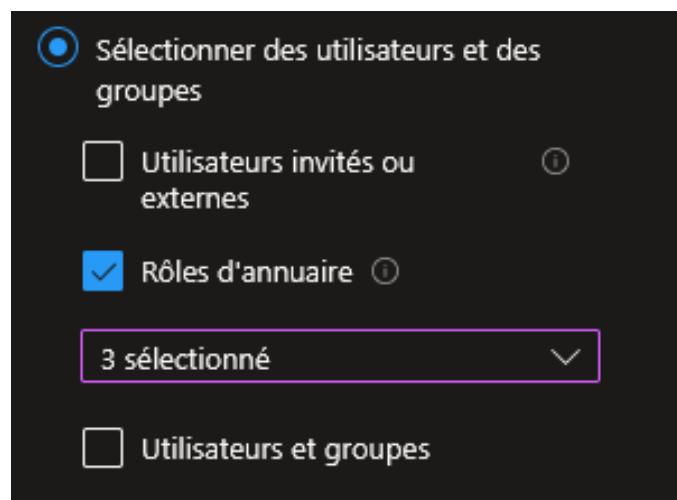


Configuration du Conditional Access et MFA

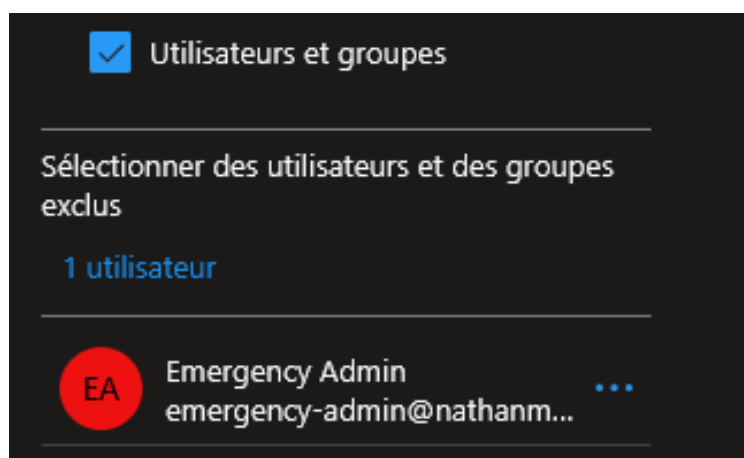
4. Enregistrer

6.3. Créer une Policy Conditional Access (Exiger le MFA)

1. Allez dans **Microsoft Entra ID > Sécurité > Accès conditionnel** (Conditional Access).
2. Cliquez sur **+ Créer une stratégie** (New policy).
3. **Nom** : CA-001-Require-MFA-Admins.
4. **Affectations** :
 - **Utilisateurs** : Cliquez sur « Utilisateurs et groupes ».
 - Onglet **Inclure** : Sélectionnez **Rôles d'annuaire** puis cochez :
 - Global Administrator
 - User Administrator
 - Billing Administrator
 - *(ajoutez les rôles admin pertinents)*



- Onglet **Exclure** : Ajoutez votre compte « break glass » (ex : emergency-admin@votretenant.onmicrosoft.com).

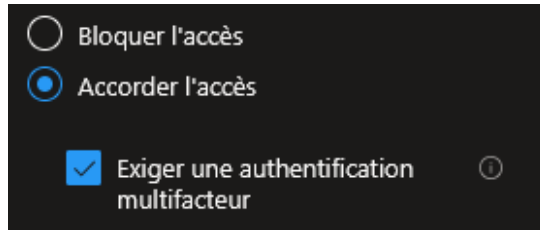


- **Ressources cibles** : Sélectionnez **Ressources**.
- **Conditions** : Laissez vide pour l'instant (toutes les conditions).

Configuration du Conditional Access et MFA

5. Contrôles d'accès :

- **Octroyer** : Sélectionnez **Accorder l'accès** puis cochez **Exiger l'authentification multifacteur**.



6. **Activer la stratégie** : Sélectionnez **Report-only** (pour tester d'abord).
7. Cliquez sur **Créer**.

Note : La policy est en mode observation. Vérifiez les journaux pendant quelques jours avant de passer en « Activé ».

Nom de stratégie	État	Date de création
CA-001-Require-MFA-Admins	Rapport seul	13/02/2026 21:19:22

6.4. Créer une Policy Conditional Access (Bloquer l'Accès par Pays)

1. **+ Nouvelle stratégie**.
2. **Nom** : CA-002-Block-Unauthorized-Countries.
3. **Affectation** :
 - **Utilisateurs** : Inclure → **Tous les utilisateurs**. Exclure → Votre compte « break glass ».
 - **Ressources cibles** : Toutes les applications cloud.
 - **Conditions** : Cliquez sur **Emplacements** (Locations).
 - Configurer : **Oui**.
 - Inclure : **Tous les réseaux et emplacements approuvés**.
 - Exclure : Sélectionnez vos Named Locations autorisés (voir 6.5 pour les créer d'abord).
4. **Contrôles d'accès** :
 - **Octroyer** : Sélectionnez **Bloquer l'accès**.
5. **État** : Report-only.
6. **Créer**.

Note : Cette policy dit : « Bloquer toutes les connexions SAUF celles venant des emplacements autorisés ». Attention à l'ordre logique des inclusions/exclusions.

Nom de stratégie	État	Date de création
CA-001-Require-MFA-Admins	Rapport seul	13/02/2026 21:19:22
CA-002-Block-Unauthorized-Countries	Rapport seul	13/02/2026 21:22:57

Configuration du Conditional Access et MFA

6.5. Créer un Named Location (Emplacement Nommé)

Note : Créez vos emplacements AVANT de les utiliser dans une policy.

1. Dans **Accès conditionnel** > **Named locations** (Emplacements nommés).
2. Cliquez sur **+ Emplacement de pays**.
3. **Nom** : Pays-Autorisés.
4. Cochez : **France, Belgique, Luxembourg** (ou les pays pertinents).
5. **Créer**.

The screenshot shows the configuration interface for a Named Location. The 'Nom' field is set to 'Pays-Autorisés'. The 'Méthode de recherche de pays' dropdown is set to 'Déterminer l'emplacement avec l'adresse IP (IPv4 et IPv6)'. There is an unchecked checkbox for 'Inclure des pays/régions inconnus'. A search bar contains the text 'france'. Below the search bar, there is a list of results with a checkbox for 'France' which is checked.

Pour un emplacement basé sur une plage IP (ex : le réseau du bureau) :

1. Cliquez sur **+ Emplacement de plages d'adresses IP**.
2. **Nom** : Bureau-Paris.
3. Cochez **Marquer comme emplacement approuvé** (trusted location).
4. Ajoutez vos plages IP publiques (ex : 203.0.113.0/24).

The screenshot shows the configuration interface for a Named Location. The 'Nom' field is set to 'Bureau-Paris'. The checkbox 'Marquer comme emplacement approuvé' is checked. Below this, there is a plus sign icon and the text '1 plage d'adresses IP trouvée'. A list shows the IP range '203.0.113.0/24' with a trash icon next to it.

5. **Créer**.

Configuration du Conditional Access et MFA

Note : Un emplacement marqué comme « approuvé » peut être utilisé comme condition supplémentaire : « Si la connexion vient d'un emplacement approuvé, ne pas exiger le MFA ».

6.6. Tester une Policy en Mode Report-Only

1. Allez dans **Microsoft Entra ID > Journaux de Connexion** (Sign-in logs).
2. Cliquez sur une connexion récente.
3. Onglet **Accès conditionnel** (Conditional Access).
4. Vous verrez chaque policy évaluée avec le résultat :
 - **Success** : La policy s'est appliquée et l'accès a été accordé.
 - **Failure** : La policy a bloqué (ou aurait bloqué en Report-only).
 - **Not applied** : Les conditions de la policy ne correspondaient pas à cette connexion.
 - **Report-only: Not applied / Would have blocked / Would have required MFA** : Ce qui se serait passé si la policy était active.

Note : Quand vous êtes satisfait des résultats après quelques jours, revenez dans la policy et passez l'état de Report-only à Activé.

Nom de stratégie	Contrôles d'oc...	Contrôles de s...	Résultat
CA-001-Require-MFA-Admins	Mfa		Rapport uniquement : action de l'utilisateur requise
CA-002-Block-Unauthorized-Cou...	Block		Rapport seul : non appliqué

① Une connexion peut également être interrompue (par exemple, bloquée, authentification multifacteur mise en cause) en raison d'une stratégie de risque utilisateur ou d'une stratégie de connexion à risque. Actuellement, cet onglet répertorie uniquement les stratégies d'accès conditionnel.

7. Méthode 2 : Configuration via Azure CLI / Microsoft Graph CLI

Note : Le Conditional Access n'est pas gérable via les commandes az classiques. Il faut utiliser l'extension Microsoft Graph CLI (az rest) ou le SDK Graph directement.

7.1. Lister les Politiques Existantes

```
az rest --method GET \  
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies" \  
--query "value[].{Name:displayName, State:state, Id:id}" -o table
```

```
nathan@srv-test:~$ az rest --method GET \  
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies" \  
--query "value[].{Name:displayName, State:state, Id:id}" -o table  
Name                               State                               Id  
-----  
CA-001-Require-MFA-Admins          enabledForReportingButNotEnforced    3322f4c2-5718-42d7-b5c8-dc9e439198ee  
nathan@srv-test:~$
```


7.2. Créer une Policy Conditional Access

```
az rest --method POST \
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies" \
--headers "Content-Type=application/json" \
--body '{
  "displayName": "CA-001-Require-MFA-Admins",
  "state": "enabledForReportingButNotEnforced",
  "conditions": {
    "users": {
      "includeRoles": [
        "62e90394-69f5-4237-9190-012177145e10"
      ],
      "excludeUsers": ["<BREAK_GLASS_USER_ID>"]
    },
    "applications": {
      "includeApplications": ["All"]
    }
  },
  "grantControls": {
    "operator": "OR",
    "builtInControls": ["mfa"]
  }
}
```

```
"createdDateTime": "2026-02-13T20:42:17.8804081Z",
"displayName": "CA-001-Require-MFA-Admins",
"grantControls": {
  "authenticationStrength": null,
  "authenticationStrength@odata.context": "https://graph.microsoft.com/v1.0/$metadata#identity/conditionalAccess/policies('3322f4c2-5718-42d7-b5c8-dc9e439198ee')/grantControls/authenticationStrength/$entity",
  "builtInControls": [
    "mfa"
  ],
  "customAuthenticationFactors": [],
  "operator": "OR",
  "termsOfUse": []
},
"id": "3322f4c2-5718-42d7-b5c8-dc9e439198ee",
"modifiedDateTime": null,
"sessionControls": null,
"state": "enabledForReportingButNotEnforced",
"templateId": null
}
nathan@srv-test:~$ |
```

Configuration du Conditional Access et MFA

Note : 62e90394-69f5-4237-9190-012177145e10 est le GUID du rôle Global Administrator. Pour trouver les GUIDs des autres rôles : `az rest --method GET --url "https://graph.microsoft.com/v1.0/directoryRoles" -o table`.

7.3. Passer une Policy en Mode Activé

```
az rest --method PATCH \  
  
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies/<POLICY_ID>" \  
  
--headers "Content-Type=application/json" \  
  
--body '{"state": "enabled"}'
```

```
nathan@srv-test:~$ az rest --method PATCH \  
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies/3322f4c2-5718-42d7-b5c8-dc9e439198ee" \  
--headers "Content-Type=application/json" \  
--body '{"state": "enabled"}' \  
nathan@srv-test:~$
```

7.4. Supprimer une Policy

```
az rest --method DELETE \  
  
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies/<POLICY_ID>"
```

```
nathan@srv-test:~$ az rest --method DELETE \  
--url "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies/3322f4c2-5718-42d7-b5c8-dc9e439198ee" \  
nathan@srv-test:~$
```

8. Méthode 3 : Configuration via PowerShell (Microsoft Graph)

8.1. Connexion au Module Microsoft Graph

1. Installer le module si nécessaire : `Install-Module Microsoft.Graph -Scope CurrentUser`

```
PS C:\Users\natha> Install-Module Microsoft.Graph -Scope CurrentUser  
  
Untrusted repository  
You are installing the modules from an untrusted repository. If you trust this repository, change its  
InstallationPolicy value by running the Set-PSRepository cmdlet. Are you sure you want to install the modules from  
'PSGallery'?  
[O] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « N ») : o
```

2. Se connecter avec les permissions nécessaires : `Connect-MgGraph -Scopes "Policy.Read.All", "Policy.ReadWrite.ConditionalAccess"`

8.2. Créer une Policy Conditional Access

```
$params = @{  
  
    DisplayName = "CA-001-Require-MFA-Admins"  
  
    State = "enabledForReportingButNotEnforced"  
  
    Conditions = @{
```

Configuration du Conditional Access et MFA

```
Users = @{
    IncludeRoles = @(
        "62e90394-69f5-4237-9190-012177145e10" # Global Admin
    )
    ExcludeUsers = @("<BREAK_GLASS_USER_ID>")
}

Applications = @{
    IncludeApplications = @("All")
}

GrantControls = @{
    Operator      = "OR"
    BuiltInControls = @("mfa")
}

New-MgIdentityConditionalAccessPolicy -BodyParameter $params
```

8.3. Lister et Vérifier les Policies

```
Get-MgIdentityConditionalAccessPolicy | Select-Object DisplayName, State, Id | Format-Table
```

Détail d'une policy :

```
Get-MgIdentityConditionalAccessPolicy -ConditionalAccessPolicyId "<POLICY_ID>" | Format-List
```

8.4. Modifier une Policy (Report-Only → Enabled)

```
Update-MgIdentityConditionalAccessPolicy `
    -ConditionalAccessPolicyId "<POLICY_ID>" `
    -State "enabled"
```

8.5. Supprimer une Policy

```
Remove-MgIdentityConditionalAccessPolicy -ConditionalAccessPolicyId "<POLICY_ID>"
```

9. Vérifications

MFA fonctionnel : Connectez-vous avec un compte admin ciblé par la policy → Si la policy est en Enabled, le MFA doit être demandé.

Report-Only : Connectez-vous, puis allez dans Sign-in logs > Conditional Access → Vérifiez que la policy apparaît avec le résultat « Report-only: Would have required MFA ».

Blocage géographique : Utilisez un VPN pour simuler une connexion depuis un pays non autorisé → Vérifiez le blocage (en Enabled) ou le log « Would have blocked » (en Report-Only).

Break glass : Connectez-vous avec le compte d'urgence → Il ne doit PAS être soumis au MFA ni bloqué.

10. Dépannage

« **AADSTS53003: Access has been blocked by Conditional Access policies** » : Une policy bloque la connexion. Connectez-vous avec le compte break glass pour accéder aux logs et identifier quelle policy est en cause. Vérifiez dans Sign-in logs > Conditional Access > l'onglet de la connexion échouée.

Tous les utilisateurs sont bloqués (lockout) : Utilisez le compte break glass. Si vous ne l'avez pas créé, contactez le support Microsoft avec une preuve de propriété du tenant. C'est pourquoi le break glass est NON négociable.

La policy ne semble pas s'appliquer : Vérifiez que l'état est bien « Enabled » et non « Report-only » ou « Disabled ». Vérifiez aussi que l'utilisateur de test est bien dans le scope d'inclusion et pas dans les exclusions. Enfin, attendez quelques minutes, les nouvelles policies peuvent mettre jusqu'à 5 minutes à se propager.

Le MFA n'est pas demandé malgré la policy : L'utilisateur a peut-être déjà satisfait le MFA récemment et le token est encore valide. Par défaut, Entra ID mémorise le MFA pendant un certain temps. Essayez en navigation privée ou attendez l'expiration du token.

« **Insufficient privileges to complete the operation** » en PowerShell/CLI : Votre compte n'a pas les permissions Graph API nécessaires. Assurez-vous d'avoir consenti aux scopes Policy.ReadWrite.ConditionalAccess lors du Connect-MgGraph.

11. Conseils et Bonnes Pratiques

Créez toujours un compte break glass en premier. Avant même de toucher au Conditional Access, créez un compte emergency-admin@tenant.onmicrosoft.com avec le rôle Global Admin, un mot de passe de 30+ caractères, PAS de MFA, et excluez-le de TOUTES les policies. Stockez le mot de passe dans un coffre physique. Surveillez son utilisation via les logs.

Configuration du Conditional Access et MFA

Commencez par Report-Only, toujours. Créez votre policy en Report-Only, observez pendant 3 à 7 jours dans les Sign-in logs, puis passez en Enabled quand vous êtes sûr qu'elle ne bloque personne par erreur.

Convention de nommage. Nommez vos policies avec un préfixe numéroté et une description de l'action : CA-001-Require-MFA-Admins, CA-002-Block-Unauthorized-Countries, CA-003-Require-Compliant-Device. Ça facilite la lecture quand vous en avez 20.

Les 5 policies recommandées par Microsoft pour commencer :

- 1) Exiger le MFA pour les administrateurs.
- 2) Exiger le MFA pour tous les utilisateurs.
- 3) Bloquer l'authentification legacy.
- 4) Exiger le MFA pour la gestion Azure (portail, CLI, PowerShell).
- 5) Bloquer les connexions depuis les pays non autorisés.

12. Procédures Liées

- [AZR-IDM-SEC Gestion des Managed Identities](#) (Les Managed Identities ne sont pas soumises au Conditional Access — c'est un avantage pour les automatisations)
- [AZR-IDM-MNT Gestion des Utilisateurs et des Rôles](#) (Les rôles Entra ID sont utilisés comme condition dans les policies Conditional Access)
- [AZR-IDM-CFG Configuration de Entra ID Connect](#) (L'identité hybride interagit avec le Conditional Access pour les utilisateurs synchronisés)